

Lista de control de cumplimiento normativo

Para revisar las regulaciones y estándares de cumplimiento normativo, lee el documento sobre [controles, marcos y cumplimiento normativo](#).

La Comisión Federal de Regulación de Energía, Corporación de Confiabilidad Eléctrica América del Norte (FERC-NERC)

La normativa FERC-NERC se aplica a organizaciones que trabajan con electricidad o que están involucradas con la red eléctrica de los Estados Unidos y América del Norte. Las empresas tienen la obligación de prepararse, mitigar y reportar cualquier incidente de seguridad potencial que pueda afectar negativamente a la red eléctrica. También están legalmente obligadas a cumplir con los Estándares de Confiabilidad de Protección de Infraestructura Crítica (CIP) definidos por la FERC.

Explicación: No aplica a la empresa, ya que no opera infraestructuras de generación, transmisión o distribución eléctrica ni sistemas vinculados a la red eléctrica de América del Norte. Por tanto, no está obligada a cumplir los estándares CIP de FERC-NERC.

X Reglamento General de Protección de Datos (RGPD)

El RGPD es una regulación general de datos de la Unión Europea (UE) que protege el procesamiento de los datos de sus residentes y su derecho a la privacidad dentro y fuera del territorio. Además, si se produce una filtración y los datos de una persona se ven comprometidos, esto debe ser informado en un plazo de 72 horas posteriores al incidente.

Explicación: Aplica porque la empresa recopila y procesa datos personales de clientes de la Unión Europea mediante su tienda online, como nombres, direcciones, correos electrónicos y datos de pedidos. Debe proteger esos datos, limitar el acceso a personal autorizado, informar sobre su uso y notificar a la autoridad competente las brechas de seguridad que puedan suponer un riesgo para las personas afectadas.

__X__ Estándares de seguridad de datos del sector de las tarjetas de pago (PCI DSS)

PCI DSS es un estándar de seguridad internacional destinado a garantizar que las organizaciones que almacenan, aceptan, procesan y transmiten información de tarjetas de crédito lo hagan en un entorno seguro.

Explicación: Aplica porque la empresa acepta pagos online con tarjeta y puede procesar, transmitir o tener acceso a datos de titulares de tarjetas. Debe implementar controles que protejan el entorno de pagos, como restricciones de acceso, autenticación segura, cifrado, monitorización y gestión de vulnerabilidades.

_____ Ley de Transferencia y Responsabilidad de los Seguros Médicos (HIPAA)

La HIPAA es una ley federal de los Estados Unidos establecida en 1996 para proteger la información médica de las personas. Esta ley prohíbe que la información de un/a paciente sea compartida sin su consentimiento. Las organizaciones tienen la obligación legal de informar a los/las pacientes en caso de que esta información se filtre.

Explicación: No aplica a la empresa, ya que no presta servicios sanitarios, no actúa como aseguradora médica ni procesa información médica protegida de pacientes en Estados Unidos. Por ello, no está sujeta a las obligaciones específicas de privacidad y notificación de brechas de HIPAA.

__X__ Controles de Sistemas y Organizaciones (SOC tipo 1, SOC tipo 2)

El SOC1 y el SOC2 se enfocan en las políticas de acceso de los usuarios y las usuarias de una organización en los diferentes niveles. Se utilizan para evaluar el cumplimiento financiero de una organización, así como los niveles de riesgo asociados. También abordan aspectos críticos como la confidencialidad, privacidad, integridad, disponibilidad, seguridad y protección general de los datos. Es importante destacar que cualquier falla en el control de estos aspectos puede resultar en posibles fraudes.

Explicación: Es recomendable aplicar controles alineados con SOC, especialmente SOC 2, porque la empresa gestiona información de clientes, sistemas de comercio electrónico y servicios tecnológicos. Estos controles permiten evaluar y reforzar la seguridad, disponibilidad, confidencialidad, integridad del procesamiento y privacidad de los datos. También ayudan a demostrar a clientes, proveedores y auditorías que existen medidas adecuadas de control de acceso y gestión de riesgos.